

# Collaborative Protection Profile for Network Devices



Version: 4.0  
2025-11-25

**National Information Assurance Partnership**

# Revision History

---

| Version | Date       | Comment                                                                 |
|---------|------------|-------------------------------------------------------------------------|
| 0.1     | 2014-09-05 | Draft published for Public review                                       |
| 0.2     | 2014-10-13 | Internal draft in response to public review comments, for iTC review    |
| 0.3     | 2014-10-17 | Draft version released to accompany CCDB review of Supporting Document. |
| 0.4     | 2015-01-26 | Incorporated comments received from the CCDB review                     |
| 1.0     | 2015-02-27 | Released for use                                                        |
| 1.1     | 2016-07-21 | Updated draft published for public review                               |
| 2.0     | 2017-05-05 | Released for use                                                        |
| 2.1     | 2018-09-24 | Released for use                                                        |
| 2.2     | 2019-12-20 | Released for use                                                        |
| 2.2e    | 2020-03-23 | Released for use                                                        |
| 3       | 2023-04-06 | Incorporated comments received. Released for use                        |
|         | 2023-12-06 | Released for use                                                        |
| 4       | 2025-11-25 | Released for use                                                        |

# Contents

---

- 1 Introduction
  - 1.1 Overview
  - 1.2 Terms
    - 1.2.1 Common Criteria Terms
    - 1.2.2 Technical Terms
  - 1.3 Compliant Targets of Evaluation
  - 1.4 PP Overview
  - 1.5 TOE Use Cases
- 2 Conformance Claims
- 3 Security Problem Description
  - 3.1 Threats
  - 3.2 Assumptions
  - 3.3 Organizational Security Policies
- 4 Security Objectives
  - 4.1 Security Objectives for the TOE
  - 4.2 Security Objectives for the Operational Environment
  - 4.3 Security Objectives Rationale
- 5 Security Requirements

|                                                   |                                                |
|---------------------------------------------------|------------------------------------------------|
| 5.1                                               | Security Functional Requirements               |
| 5.1.1                                             | Security Audit (FAU)                           |
| 5.1.2                                             | Cryptographic Support (FCS)                    |
| 5.1.3                                             | Identification and Authentication (FIA)        |
| 5.1.4                                             | Security Management (FMT)                      |
| 5.1.5                                             | Protection of the TSF (FPT)                    |
| 5.1.6                                             | TOE Access (FTA)                               |
| 5.1.7                                             | Trusted Channel (FTP_ITC)                      |
| 5.1.8                                             | TOE Security Functional Requirements Rationale |
| 5.2                                               | Security Assurance Requirements                |
| 5.2.1                                             | Class ADV: Development                         |
| 5.2.2                                             | Class AGD: Guidance Documents                  |
| 5.2.3                                             | Class ALC: Life-cycle Support                  |
| 5.2.4                                             | Class ASE: ST Evaluation                       |
| 5.2.5                                             | Class ATE: Tests                               |
| 5.2.6                                             | Class AVA: Vulnerability Assessment            |
| Appendix A - Optional Requirements                |                                                |
| A.1                                               | Strictly Optional Requirements                 |
| A.1.1                                             | Class ALC: Life-cycle Support                  |
| A.1.2                                             | Security Audit (FAU)                           |
| A.1.3                                             | Communication (FCO)                            |
| A.1.4                                             | Cryptographic Support (FCS)                    |
| A.1.5                                             | Protection of the TSF (FPT)                    |
| A.1.6                                             | Trusted Channel (FTP_ITC)                      |
| A.2                                               | Objective Requirements                         |
| A.3                                               | Implementation-dependent Requirements          |
| Appendix B - Selection-based Requirements         |                                                |
| B.1                                               | Security Audit (FAU)                           |
| B.2                                               | Cryptographic Support (FCS)                    |
| B.3                                               | Security Management (FMT)                      |
| B.4                                               | Protection of the TSF (FPT)                    |
| Appendix C - Entropy Documentation and Assessment |                                                |
| Appendix D - Glossary                             |                                                |
| D.1                                               | Terms                                          |
| D.1.1                                             | Common Criteria Terms                          |
| D.1.2                                             | Technical Terms                                |
| Appendix E - Acronyms                             |                                                |
| Appendix F - Bibliography                         |                                                |

# 1 Introduction

## 1.1 Overview

---

## 1.2 Terms

---

The following sections list Common Criteria and technology terms used in this document.

### 1.2.1 Common Criteria Terms

|                                        |                                                                                                                                                                                                                                                                                             |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Assurance                              | Grounds for confidence that a TOE meets the SFRs <a href="#">[CC]</a> .                                                                                                                                                                                                                     |
| Base Protection Profile (Base-PP)      | Protection Profile used as a basis to build a PP-Configuration.                                                                                                                                                                                                                             |
| Collaborative Protection Profile (cPP) | A Protection Profile developed by international technical communities and approved by multiple schemes.                                                                                                                                                                                     |
| Common Criteria (CC)                   | Common Criteria for Information Technology Security Evaluation (International Standard ISO/IEC 15408).                                                                                                                                                                                      |
| Common Criteria Testing Laboratory     | Within the context of the Common Criteria Evaluation and Validation Scheme (CCEVS), an IT security evaluation facility accredited by the National Voluntary Laboratory Accreditation Program (NVLAP) and approved by the NIAP Validation Body to conduct Common Criteria-based evaluations. |
| Common Evaluation Methodology (CEM)    | Common Evaluation Methodology for Information Technology Security Evaluation.                                                                                                                                                                                                               |
| Direct Rationale                       | A type of Protection Profile, PP-Module, or Security Target in which the security problem definition (SPD) elements are mapped directly to the SFRs and possibly to the security objectives for the operational environment. There are no security objectives for the TOE.                  |
| Distributed TOE                        | A TOE composed of multiple components operating as a logical whole.                                                                                                                                                                                                                         |
| Extended Package (EP)                  | A deprecated document form for collecting SFRs that implement a particular protocol, technology, or functionality. See Functional Packages.                                                                                                                                                 |
| Functional Package (FP)                | A document that collects SFRs for a particular protocol, technology, or functionality.                                                                                                                                                                                                      |
| Operational Environment (OE)           | Hardware and software that are outside the TOE boundary that support the TOE functionality and security policy.                                                                                                                                                                             |
| Protection Profile (PP)                | An implementation-independent set of security requirements for a category of products.                                                                                                                                                                                                      |

|                                                     |                                                                                                                                   |
|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Protection Profile Configuration (PP-Configuration) | A comprehensive set of security requirements for a product type that consists of at least one Base-PP and at least one PP-Module. |
| Protection Profile Module (PP-Module)               | An implementation-independent statement of security needs for a TOE type complementary to one or more Base-PPs.                   |
| Security Assurance Requirement (SAR)                | A requirement to assure the security of the TOE.                                                                                  |
| Security Functional Requirement (SFR)               | A requirement for security enforcement by the TOE.                                                                                |
| Security Target (ST)                                | A set of implementation-dependent security requirements for a specific product.                                                   |
| Target of Evaluation (TOE)                          | The product under evaluation.                                                                                                     |
| TOE Security Functionality (TSF)                    | The security functionality of the product under evaluation.                                                                       |
| TOE Summary Specification (TSS)                     | A description of how a TOE satisfies the SFRs in an ST.                                                                           |

## 1.2.2 Technical Terms

## 1.3 Compliant Targets of Evaluation

---

## 1.4 PP Overview

---

words

## 1.5 TOE Use Cases

---

Words

## **2 Conformance Claims**

# 3 Security Problem Description

A Network Device has a network infrastructure role that it is designed to provide. In doing so, the Network Device communicates with other Network Devices and other network entities (i.e. entities not defined as Network Devices because they do not have an infrastructure role) over the network. At the same time, it must provide a minimal set of common security functionality expected by all Network Devices. The security problem to be addressed by a compliant Network Device is defined as this set of common security functionality that addresses the threats that are common to Network Devices, as opposed to those that might be targeting the specific functionality of a specific type of Network Device. The set of common security functionality addresses communication with the Network Device, both authorized and unauthorized, the ability to perform valid and secure updates, the ability to audit device activity, the ability to securely store and utilize device and Administrator credentials and data, and the ability to self-test critical device components for failures.

## 3.1 Threats

---

### T.LIMITED\_PHYSICAL\_ACCESS

An attacker may attempt to access data on the `QS` while having a limited amount of time with the physical device.

### T.LOCAL\_ATTACK

An attacker may compromise applications running on the `QS`. The compromised application may provide maliciously formatted input to the `QS` through a variety of channels including unprivileged system calls and messaging via the file system.

### T.NETWORK\_ATTACK

An attacker is positioned on a communications channel or elsewhere on the network infrastructure. Attackers may engage in communications with applications and services running on or part of the `QS` with the intent of compromise. Engagement may consist of altering existing legitimate communications.

### T.NETWORK\_EAVESDROP

An attacker is positioned on a communications channel or elsewhere on the network infrastructure. Attackers may monitor and gain access to data exchanged between applications and services that are running on or part of the `QS`.

## 3.2 Assumptions

---

### A.PLATFORM

The `QS` relies upon a trustworthy computing platform for its execution. This underlying platform is out of scope of this `PP`.

### A.PROPER\_ADMIN

The administrator of the `QS` is not careless, willfully negligent or hostile, and administers the `QS` within compliance of the applied enterprise security policy.

### A.PROPER\_USER

The user of the `QS` is not willfully negligent or hostile, and uses the software in compliance with the applied enterprise security policy. At the same time, malicious software could act *as* the user, so requirements which confine malicious subjects are still in scope.

### 3.3 Organizational Security Policies

---

This PP defines no Organizational Security Policies.



# 4 Security Objectives

## 4.1 Security Objectives for the TOE

---

## 4.2 Security Objectives for the Operational Environment

---

The following security objectives for the operational environment assist the QSS in correctly providing its security functionality. These track with the assumptions about the environment.

**OE.PLATFORM**

The QSS relies on being installed on trusted hardware.

**OE.PROPER\_ADMIN**

The administrator of the QSS is not careless, willfully negligent or hostile, and administers the QSS within compliance of the applied enterprise security policy.

**OE.PROPER\_USER**

The user of the QSS is not willfully negligent or hostile, and uses the software within compliance of the applied enterprise security policy. Standard user accounts are provisioned in accordance with the least privilege model. Users requiring higher levels of access should have a separate account dedicated for that use.

## 4.3 Security Objectives Rationale

---

This section describes how the assumptions, threats, and organizational security policies map to the security objectives.

Table 1: Security Objectives Rationale

| Threat, Assumption, or OSP | Security Objectives | Rationale                                                                                 |
|----------------------------|---------------------|-------------------------------------------------------------------------------------------|
| A.PLATFORM                 | OE.PLATFORM         | The operational environment objective OE.PLATFORM is realized through A.PLATFORM.         |
| A.PROPER_ADMIN             | OE.PROPER_ADMIN     | The operational environment objective OE.PROPER_ADMIN is realized through A.PROPER_ADMIN. |
| A.PROPER_USER              | OE.PROPER_USER      | The operational environment objective OE.PROPER_USER is realized through A.PROPER_USER.   |

# 5 Security Requirements

This chapter describes the security requirements which have to be fulfilled by the product under evaluation. Those requirements comprise functional components from Part 2 and assurance components from Part 3 of [CC]. The following conventions are used for the completion of operations:

- **Refinement** operation (denoted by **bold text** or ~~striktthrough-text~~): Is used to add details to a requirement or to remove part of the requirement that is made irrelevant through the completion of another operation, and thus further restricts a requirement.
- **Selection** (denoted by *italicized text*): Is used to select one or more options provided by the [CC] in stating a requirement.
- **Assignment** operation (denoted by *italicized text*): Is used to assign a specific value to an unspecified parameter, such as the length of a password. Showing the value in square brackets indicates assignment.
- **Iteration** operation: Is indicated by appending the SFR name with a slash and unique identifier suggesting the purpose of the operation, e.g. "/EXAMPLE1."

## 5.1 Security Functional Requirements

---

### 5.1.1 Security Audit (FAU)

#### FAU\_GEN.1 Audit data generation

##### FAU\_GEN.1.1

The T<sub>TSF</sub> shall be able to generate audit data of the following auditable events:

1. Start-up and shut-down of the audit functions;
2. All auditable events for the not specified level of audit; and
3. *All administrative actions comprising:*
  1. *Administrative login and logout (name of Administrator account shall be logged if individual accounts are required for Administrators).*
  2. *Changes to T<sub>TSF</sub> data related to configuration changes (in addition to the information that a change occurred it shall be logged what has been changed).*
  3. *Generating/import of, changing, or deleting of cryptographic keys (in addition to the action itself a unique key name or key reference shall be logged).*
  - 4.

[**selection:** Resetting passwords (name of related Administrator account shall be logged), no other actions, [**assignment:** list of other uses of privileges]]

;

4. *Specifically defined auditable events listed in Table 2.*

### **Application Note: Application Note 1**

If the list of ‘administrative actions’ appears to be incomplete, the assignment in the selection should be used to list additional administrative actions which are audited.

The requirement to audit the "Generating/import of, changing, or deleting of cryptographic keys" refers to all types of cryptographic keys which are intended to be used longer than for just one session (i.e., it does not refer to ephemeral keys/session keys). The requirement applies to all named changes independently from how they are invoked. A cryptographic key could be generated automatically during initial start-up without administrator intervention or through administrator intervention. This requirement also applies to the management of cryptographic keys by adding, replacing or removing trust anchors in the TOE’s trust store. In all related cases the changes to cryptographic keys need to be audited together with a unique key name, key reference or unique identifier for the corresponding certificate.

The ST author replaces the cross-reference to the table of audit events with an appropriate cross-reference for the ST.

For distributed TOEs, each component must generate an audit record for each of the SERs that it implements. If more than one TOE component is involved when an audit event is triggered, the event has to be audited on each component (e.g., rejection of a connection by one component while attempting to establish a secure communication channel between two components should result in an audit event being generated by both components). This is not limited to error cases but also includes events about successful actions like successful build up/tear down of a secure communication channel between TOE components.

### **Application Note 2**

The ST author can include other auditable events directly in the table; they are not limited to the list presented.

The audit events that correspond to defined management functions are highly dependent on the FMT\_SMF.1 selections. Therefore, there is only a generic requirement specified in Table 2 for FMT\_SMF.1 (‘All management activities of TSE data.’) that is intended to cover all mandatory and selection-based management functions. If, for example, the ‘Ability to enable or disable automatic checking for updates or automatic updates’ is selected as part of FMT\_SMF.1, all actions of enabling or disabling automatic checking for updates or automatic updates should be audited. Audit of management functions is intended to record both the issuing and the result of the command/administrative action. The corresponding audit event can be recorded as either a single audit record or multiple audit records. In cases where a management function could conceivably fail, such as updating the TOE, there must exist an audit record indicating the outcome, such as the successful completion of the update process.

With respect to FAU\_GEN.1.1, FMT\_SMF.1 and FMT\_MOF.1/Services the term ‘services’ refers to trusted path and trusted channel communications, on demand self-tests, trusted update and Administrator sessions (that exist under the trusted path) (e.g., netconf).

## **FAU\_GEN.1.2**

The TSE shall record within the audit data at least the following information:

1. Date and time of the auditable event, type of event, subject identity (~~if applicable~~), and the outcome (success or failure) of the event; and

2. For each auditable event type, based on the auditable event definitions of the functional components included in the **cPP**, **PP-Module**, functional package or **ST**, information specified in column three of Table 2.

### **Application Note: Application Note 3**

The **ST** author replaces the cross-reference to the table of audit events with an appropriate cross-reference for the **ST**. If the **TOE** does not implement functionality that enables the administrator to configure local audit settings, then item **FAU\_STG\_EXT.1** in Table 2 should be considered ‘trivially satisfied’ and the **ST** author should include an explanation that the local audit is not configurable in the **TSS**.

The date and time information for any audit event should be recorded as part of each audit record to ensure the timing of the event can be unambiguously determined from the data contained in the audit record. The representation of date and time information recorded for each event needs to allow unambiguous determination of at least day, month and year information for the date and hours, minutes and second information for the time.

### **Application Note 4**

Additional audit events will apply to the **TOE** depending on the optional and selection-based requirements adopted from Annex A, Annex B, **PP-Module(s)**, and functional package(s). For all **SFRs** included in the **ST**, the **ST** must include the relevant additional auditable events specified in Table 10 for optional **SFRs**, Table 11 for selection-based **SFRs**, the claimed **PP-Module(s)**, and the claimed functional package(s). All audit events defined in Table 2 have to be included in the **ST** as they are mandatory.

## **Evaluation Activities** ▼

**FAU\_GEN.1**

*Something*

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## **FAU\_GEN.2 User identity association**

### **FAU\_GEN.2.1**

For audit events resulting from actions of identified users, the **TSE** shall be able to associate each auditable event with the identity of the user that caused the event.

### **Application Note: Application Note 5**

Where an auditable event is triggered by another component, the component that records the event must associate the event with the identity of the initiating component that caused the event (applies to distributed **TOEs** only).

*FAU\_GEN.2*

*Something*

*TSS*

*ABC*

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

## FAU\_STG\_EXT.1 Protected Audit Event Storage

### FAU\_STG\_EXT.1.1

The *TSE* shall be able to transmit the generated audit data to an external *IT* entity using a trusted channel according to [FTP\\_ITC.1](#).

**Application Note: Application Note 6**

For selecting the option of transmission of generated audit data to an external *IT* entity the *TOE* relies on a non-TOE audit server for storage and review of audit records. The storage of these audit records and the ability to allow the Administrator to review these audit records is provided by the operational environment in that case. Since the external audit server is not part of the *TOE*, there are no requirements on it except the capabilities for [FTP\\_ITC.1](#) transport for audit data. No requirements are placed upon the format or underlying protocol of the audit data being transferred. The *TOE* must be capable of being configured to transfer audit data to an external *IT* entity without Administrator intervention. Manual transfer would not meet the requirements. Transmission could be done in real-time or periodically. If the transmission is not done in real-time then the *TSS* describes what event stimulates the transmission to be made and what range of frequencies the *TOE* supports for making transfers of audit data to the audit server, the *TSS* also suggests typical acceptable frequencies for the transfer.

For distributed *TOEs*, each component must be able to export audit data across a protected channel external ([FTP\\_ITC.1](#)) or intercomponent ([FPT\\_ITT.1](#) or [FTP\\_ITC.1](#)) as appropriate. At least one component of the *TOE* must be able to export audit records via [FTP\\_ITC.1](#) such that all *TOE* audit records can be exported to an external *IT* entity.

An ‘external *IT* entity’ (physical or virtualized) is another device or computer on the network in which the *TOE* no longer has access to the audit records. This can be a physical or virtualized entity.

### FAU\_STG\_EXT.1.2

The *TSE* shall be able to store generated audit data on the *TOE* itself. In addition

[**selection:** *The *TOE* shall consist of a single standalone component that stores audit data locally, The *TOE* shall be a distributed *TOE* that stores audit data on the following *TOE* components: [assignment: identification of *TOE* components], The *TOE* shall be a distributed *TOE* with storage of audit data provided externally for the following *TOE* components: [assignment: list of *TOE* components that do not*

*store audit data locally and the other T.O.E components to which they transmit their generated audit data]]*

#### **Application Note: Application Note 7**

If the T.O.E is a standalone T.O.E (i.e., not a distributed T.O.E) the option 'The T.O.E should consist of a single standalone component that stores audit data locally' must be selected.

If the T.O.E is a distributed T.O.E, the option 'The T.O.E should be a distributed T.O.E that stores audit data on the following T.O.E components: [assignment: identification of T.O.E components]' must be selected and the T.O.E components which store audit data locally must be listed in the assignment. Since all T.O.Es are required to provide functions to store audit data locally this option needs to be selected for all distributed T.O.Es. In addition, [FAU\\_GEN\\_EXT.1](#) and [FAU\\_STG\\_EXT.4](#) must be claimed in the S.T. If the distributed T.O.E consists only of components which are storing audit data locally, it is sufficient to select only the option 'The T.O.E should be a distributed T.O.E that stores audit data on the following T.O.E components: [assignment: identification of T.O.E components]' and add [FAU\\_GEN\\_EXT.1](#) and [FAU\\_STG\\_EXT.4](#).

If the T.O.E is a distributed T.O.E and some T.O.E components are not storing audit data locally, the option 'The T.O.E should be a distributed T.O.E with storage of audit data provided externally for the following T.O.E components: [assignment: list of T.O.E components that do not store audit data locally and the other T.O.E components to which they transmit their generated audit data]' must be selected in addition to the option 'The T.O.E should be a distributed T.O.E that stores audit data on the following T.O.E components: [assignment: identification of T.O.E components]'. In that case [FAU\\_STG\\_EXT.5](#) must be claimed in the S.T. in addition to [FAU\\_GEN\\_EXT.1](#) and [FAU\\_STG\\_EXT.4](#). For the option 'The T.O.E should be a distributed T.O.E with storage of audit data provided externally for the following T.O.E components: [assignment: list of T.O.E components that do not store audit data locally and the other T.O.E components to which they transmit their generated audit data]' the T.O.E components that do not store audit data locally should be mapped to the T.O.E components to which they transmit their generated audit data.

For distributed T.O.Es, this S.F.R can be fulfilled either by every T.O.E component storing its own security audit data locally or by one or more T.O.E components storing audit data locally and other T.O.E components which are not storing audit information locally sending security audit data to other T.O.E components for local storage. For the transfer of security audit data between T.O.E components a protected channel according to [FTP\\_ITC.1](#) or [FPT\\_ITT.1](#) must be used. The T.SS describes which T.O.E components store security audit data locally and which T.O.E components do not store security audit data locally. For the latter, the T.SS describes which other T.O.E component the audit data is stored locally.

For pNDs, 'on the T.O.E itself' or 'locally' means on storage inside or directly attached to the ND chassis and accessible by the networking functionality.

For vNDs, local storage is any storage accessible by T.O.E software. In a virtualized environment, 'local' storage is under the control of the VS and may be physically located on the local host, but it could also be located on a network drive or storage array.

#### **FAU\_STG\_EXT.1.3**

The T.SF shall maintain a [**selection:** *log file, database, buffer*, [**assignment:** *other local logging method*]] of audit records in the event that an interruption of communication with the remote audit server occurs.

#### FAU\_STG\_EXT.1.4

The TSSF shall be able to store [**selection:** *persistent, non-persistent*] audit records locally with a minimum storage size of [**assignment:** *number of records and/or file/buffer size(s)*]

##### **Application Note: Application Note 8**

Persistent logging is defined as any record(s) that is retained through power off, power failure, or reboot. This requirement allows for the TSSF to implement logging either persistent log records or non-persistent log records that may be cleared on reboot of the TOE.

#### FAU\_STG\_EXT.1.5

The TSSF shall [**selection:** *drop new audit data, overwrite previous audit records according to the following rule: [assignment: rule for overwriting previous audit records], [assignment: other action]*] when the local storage space for audit data is full.

##### **Application Note: Application Note 9**

The ST author may use the "other action" assignment to describe other measurable behaviour (e.g., frequency of log file rotation based on size and/or age of log files).

For distributed TOEs, each component is not required to store generated audit data locally, but the overall TOE needs to be able to store audit data locally. Each component must at least provide the ability to temporarily buffer audit information locally to ensure that audit records are preserved in case of network connectivity issues. Buffering audit information locally, does not necessarily involve non-volatile memory: audit information could be buffered in volatile memory. However, the local storage of audit information in the sense of [FAU\\_STG\\_EXT.1.5](#) needs to be done in non-volatile memory. For every component which performs local storage of audit information, the behaviour when local storage is exhausted needs to be described. For every component which is buffering audit information instead of storing audit information locally itself, it needs to be described what happens in case the buffer space is exhausted.

#### FAU\_STG\_EXT.1.6

The TSSF shall provide the following mechanisms for administrative access to locally stored audit records [**selection:** *none, manual export, ability to view locally*].

##### **Application Note: Application Note 10**

If "ability to view locally" is selected in [FAU\\_STG\\_EXT.1.6](#), then [FAU\\_SAR.1](#) from Annex B must be included in the ST.

### Evaluation Activities ▼

#### [FAU\\_STG\\_EXT.1](#)

Something

TSS

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

## 5.1.2 Cryptographic Support (FCS)

### FCS\_CKM.1/AKG Cryptographic Key Generation - Asymmetric Key

### FCS\_CKM.6 Timing and Event of Cryptographic Key Destruction

FCS\_CKM.6.1

The TOE shall

#### Evaluation Activities ▼

[FCS\\_CKM.6](#)

Something

TSS

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

### FCS\_CKM\_EXT.7 Cryptographic Key Agreement

FCS\_CKM\_EXT.7.1

The TOE shall

#### Evaluation Activities ▼

[FCS\\_CKM\\_EXT.7](#)

Something

TSS

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

### FCS\_COP.1/DataEncryption Cryptographic Operation (AES Data Encryption/Decryption)

FCS\_COP.1.1/DataEncryption

The TOE shall



## Evaluation Activities ▼

[FCS\\_COP.1/DataEncryption](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FCS\_COP.1/Hash Cryptographic Operation (Hash Algorithm)

FCS\_COP.1.1/Hash

The TOE shall

## Evaluation Activities ▼

[FCS\\_COP.1/Hash](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FCS\_COP.1/KeyedHash Cryptographic Operation (Keyed Hash Algorithm)

FCS\_COP.1.1/KeyedHash

The TOE shall

## Evaluation Activities ▼

[FCS\\_COP.1/KeyedHash](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## **FCS\_COP.1/SigGen Cryptographic Operation - Signature Generation**

FCS\_COP.1.1/SigGen

The T.O.E shall

### **Evaluation Activities** ▼

[FCS\\_COP.1/SigGen](#)

*Something*

TSS

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

## **FCS\_COP.1/SigVer Cryptographic Operation - Signature Verification**

FCS\_COP.1.1/SigVer

The T.SF shall

## **FCS\_RBG.1 Random Bit Generation**

FCS\_RBG.1.1

The T.O.E shall

### **Evaluation Activities** ▼

[FCS\\_RBG.1](#)

*Something*

TSS

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

## **5.1.3 Identification and Authentication (FIA)**

### **FIA\_AFL.1 Authentication Failure Management (Refinement)**

FIA\_AFL.1.1

The TOE shall

## Evaluation Activities ▼

[FIA\\_AFL.1](#)

Something

TSS

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## **FIA\_PMG\_EXT.1 Password Management**

FIA\_PMG\_EXT.1.1

The TOE shall

## Evaluation Activities ▼

[FIA\\_PMG\\_EXT.1](#)

Something

TSS

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## **FIA\_PSK\_EXT.1 Pre-Shared Key Composition**

FIA\_PSK\_EXT.1.1

The TSE shall

## **FIA\_UAU.7 Protected Authentication Feedback**

FIA\_UAU.7.1

The TOE shall

## Evaluation Activities ▼

[FIA\\_UAU.7](#)

Something

TSS

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**FIA\_UIA\_EXT.1 User Identification and Authentication**

FIA\_UIA\_EXT.1.1

The TOE shall

**Evaluation Activities ▼**

[FIA\\_UIA\\_EXT.1](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**5.1.4 Security Management (FMT)**

**FMT\_MOF.1/ManualUpdate Management of Security Functions Behaviour**

FMT\_MOF.1.1/ManualUpdate

The TOE shall

**Evaluation Activities ▼**

[FMT\\_MOF.1/ManualUpdate](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**FMT\_MTD.1/CoreData Management of TSF Data**

FMT\_MTD.1.1/CoreData

The TOE shall

## Evaluation Activities ▼

[FMT\\_MTD.1/CoreData](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FMT\_SMF.1 Specification of Management Functions

FMT\_SMF.1.1

The TOE shall

## Evaluation Activities ▼

[FMT\\_SMF.1](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FMT\_SMR.2 Restrictions on security roles

FMT\_SMR.2.1

The TOE shall

## Evaluation Activities ▼

[FMT\\_SMR.2](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

## 5.1.5 Protection of the TSF (FPT)

### FPT\_APW\_EXT.1 Protection of Administrator Passwords

FPT\_APW\_EXT.1.1

The TOE shall

#### Evaluation Activities ▼

[FPT\\_APW\\_EXT.1](#)

Something

TSS

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

### FPT\_SKP\_EXT.1 Protection of TSF Data (for reading of all pre-shared, symmetric and private keys)

FPT\_SKP\_EXT.1.1

The TOE shall

#### Evaluation Activities ▼

[FPT\\_SKP\\_EXT.1](#)

Something

TSS

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

### FPT\_STM\_EXT.1 Reliable Time Stamps

FPT\_STM\_EXT.1.1

The TOE shall

## Evaluation Activities ▼

[FPT\\_STM\\_EXT.1](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FPT\_TST\_EXT.1 TSF Testing

FPT\_TST\_EXT.1.1

The ~~T.O.E~~ shall

## Evaluation Activities ▼

[FPT\\_TST\\_EXT.1](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FPT\_TUD\_EXT.1 Trusted Update

FPT\_TUD\_EXT.1.1

The ~~T.O.E~~ shall

## Evaluation Activities ▼

[FPT\\_TUD\\_EXT.1](#)

Something

**TSS**

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## 5.1.6 TOE Access (FTA)

### FTA\_SSL.3 TSF-initiated Termination (Refinement)

FTA\_SSL.3.1

The TOE shall

#### Evaluation Activities ▼

[FTA\\_SSL.3](#)

Something

**TSS**

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

### FTA\_SSL.4 User-initiated Termination (Refinement)

FTA\_SSL.4.1

The TOE shall

#### Evaluation Activities ▼

[FTA\\_SSL.4](#)

Something

**TSS**

ABC

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

### FTA\_SSL\_EXT.1 TSF-initiated Session Locking

FTA\_SSL\_EXT.1.1

The TOE shall

#### Evaluation Activities ▼



[FTA\\_SSL\\_EXT.1](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**FTA\_TAB.1 Default TOE Access Banners (Refinement)**

FTA\_TAB.1.1

The TOE shall

**Evaluation Activities** ▼

[FTA\\_TAB.1](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**5.1.7 Trusted Channel (FTP\_ITC)**

**FTP\_ITC.1 Inter-TSF Trusted Channel (Refinement)**

FTP\_ITC.1.1

The TOE shall

FTP\_ITC.1.2

The TOE shall

FTP\_ITC.1.3

The TOE shall

**Evaluation Activities** ▼

[FTP\\_ITC.1](#)

Something

**TSS**

ABC

**Guidance**

There are no additional Guidance evaluation activities for this component.

**Tests**

There are no test activities for this component.

**FTP\_TRP.1/Admin Trusted Path (Refinement)**

FTP\_TRP.1.1/Admin

The T<sub>TOE</sub> shall

**Evaluation Activities** ▼

[FTP\\_TRP.1/Admin](#)

Something

T<sub>SS</sub>

ABC

**Guidance**

There are no additional Guidance evaluation activities for this component.

**Tests**

There are no test activities for this component.

**5.1.8 TOE Security Functional Requirements Rationale**

The following rationale provides justification for each security objective for the T<sub>TOE</sub>, showing that the S<sub>FR</sub>s are suitable to meet and achieve the security objectives:

**Table 2: S<sub>FR</sub> Rationale**

| Objective | Addressed by | Rationale |
|-----------|--------------|-----------|
|-----------|--------------|-----------|

**5.2 Security Assurance Requirements**

**5.2.1 Class ADV: Development**

The information about the T<sub>TOE</sub> is contained in the guidance documentation available to the end user as well as the T<sub>SS</sub> portion of the S<sub>T</sub>. The T<sub>TOE</sub> developer must concur with the description of the product that is contained in the T<sub>SS</sub> as it relates to the functional requirements. The evaluation activities contained in [Section 5.1 Security Functional Requirements](#) should provide the S<sub>T</sub> authors with sufficient information to determine the appropriate content for the T<sub>SS</sub> section.

**ADV\_FSP.1 Basic Functional Specification (ADV\_FSP.1)**

The functional specification describes the T<sub>SFIs</sub>. It is not necessary to have a formal or complete specification of these interfaces. Additionally, because T<sub>TOEs</sub> conforming to this PP will necessarily have interfaces to the Operational Environment that are not directly invocable by T<sub>TOE</sub> users, there is little point

specifying that such interfaces be described in and of themselves since only indirect testing of such interfaces may be possible. For this **PP**, the activities for this family should focus on understanding the interfaces presented in the **TSS** in response to the functional requirements and the interfaces presented in the AGD documentation. No additional “functional specification” documentation is necessary to satisfy the evaluation activities specified. The interfaces that need to be evaluated are characterized through the information needed to perform the assurance activities listed, rather than as an independent, abstract list.

### Developer action elements:

ADV\_FSP.1.1D

The developer shall provide a functional specification.

ADV\_FSP.1.2D

The developer shall provide a tracing from the functional specification to the **SFRs**.

### Content and presentation elements:

ADV\_FSP.1.1C

The functional specification shall describe the purpose and method of use for each **SFR**-enforcing and **SFR**-supporting **TSEI**.

ADV\_FSP.1.2C

The functional specification shall identify all parameters associated with each **SFR**-enforcing and **SFR**-supporting **TSEI**.

ADV\_FSP.1.3C

The functional specification shall provide rationale for the implicit categorization of interfaces as **SFR**-non-interfering.

ADV\_FSP.1.4C

The tracing shall demonstrate that the **SFRs** trace to **TSEIs** in the functional specification.

### Evaluator action elements:

ADV\_FSP.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ADV\_FSP.1.2E

The evaluator shall determine that the functional specification is an accurate and complete instantiation of the **SFRs**.

### Evaluation Activities ▼

#### **ADV\_FSP.1**

*There are no specific assurance activities associated with these **SARs**, except ensuring the information is provided. The functional specification documentation is provided to support the evaluation activities described in [Section 5.1 Security Functional Requirements](#), and other activities described for AGD, ATE, and AVA **SARs**. The requirements on the content of the functional specification information is implicitly assessed by virtue of the other assurance activities being performed; if the evaluator is unable to perform an activity because there is insufficient interface information, then an adequate functional specification has not been provided.*

## 5.2.2 Class AGD: Guidance Documents

The guidance documents will be provided with the ST. Guidance must include a description of how the IT personnel verifies that the Operational Environment can fulfill its role for the security functionality. The documentation should be in an informal style and readable by the IT personnel. Guidance must be provided for every operational environment that the product supports as claimed in the ST. This guidance includes instructions to successfully install the TSF in that environment; and Instructions to manage the security of the TSF as a product and as a component of the larger operational environment. Guidance pertaining to particular security functionality is also provided; requirements on such guidance are contained in the evaluation activities specified with each requirement.

### AGD\_OPE.1 Operational User Guidance (AGD\_OPE.1)

#### Developer action elements:

##### AGD\_OPE.1.1D

The developer shall provide operational user guidance.

**Application Note:** The operational user guidance does not have to be contained in a single document. Guidance to users, administrators and application developers can be spread among documents or web pages. Rather than repeat information here, the developer should review the assurance activities for this component to ascertain the specifics of the guidance that the evaluator will be checking for. This will provide the necessary information for the preparation of acceptable guidance.

#### Content and presentation elements:

##### AGD\_OPE.1.1C

The operational user guidance shall describe, for each user role, the user-accessible functions and privileges that should be controlled in a secure processing environment, including appropriate warnings.

**Application Note:** User and administrator are to be considered in the definition of user role.

##### AGD\_OPE.1.2C

The operational user guidance shall describe, for each user role, how to use the available interfaces provided by the TOE in a secure manner.

##### AGD\_OPE.1.3C

The operational user guidance shall describe, for each user role, the available functions and interfaces, in particular all security parameters under the control of the user, indicating secure values as appropriate.

**Application Note:** This portion of the operational user guidance should be presented in the form of a checklist that can be quickly executed by IT personnel (or end-users, when necessary) and suitable for use in compliance activities. When possible, this guidance is to be expressed in the eXtensible Configuration Checklist Description Format (XCCDF) to support security automation. Minimally, it should be presented in a structured format which includes a title for each configuration item, instructions for achieving the secure configuration, and any relevant rationale.

##### AGD\_OPE.1.4C

The operational user guidance shall, for each user role, clearly present each type of security-relevant event relative to the user-accessible functions that need to be

performed, including changing the security characteristics of entities under the control of the TSE.

#### AGD\_OPE.1.5C

The operational user guidance shall identify all possible modes of operation of the TOE (including operation following failure or operational error), their consequences, and implications for maintaining secure operation.

#### AGD\_OPE.1.6C

The operational user guidance shall, for each user role, describe the security measures to be followed in order to fulfill the security objectives for the operational environment as described in the ST.

#### AGD\_OPE.1.7C

The operational user guidance shall be clear and reasonable.

### Evaluator action elements:

#### AGD\_OPE.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

### Evaluation Activities ▼

#### *AGD\_OPE.1*

*Some of the contents of the operational guidance are verified by the assurance activities in [Section 5.1 Security Functional Requirements](#) and evaluation of the QS according to the [\[CEM\]](#). The following additional information is also required. If cryptographic functions are provided by the QS, the operational guidance shall contain instructions for configuring the cryptographic engine associated with the evaluated configuration of the QS. It shall provide a warning to the administrator that use of other cryptographic engines was not evaluated nor tested during the CC evaluation of the QS. The documentation must describe the process for verifying updates to the QS by verifying a digital signature – this may be done by the QS or the underlying platform. The evaluator will verify that this process includes the following steps: Instructions for obtaining the update itself. This should include instructions for making the update accessible to the QS (e.g., placement in a specific directory). Instructions for initiating the update process, as well as discerning whether the process was successful or unsuccessful. This includes generation of the hash/digital signature. The QS will likely contain security functionality that does not fall in the scope of evaluation under this PP. The operational guidance shall make it clear to an administrator which security functionality is covered by the evaluation activities.*

### AGD\_PRE.1 Preparative Procedures (AGD\_PRE.1)

#### Developer action elements:

#### AGD\_PRE.1.1D

The developer shall provide the TOE, including its preparative procedures.

#### Content and presentation elements:

#### AGD\_PRE.1.1C

The preparative procedures shall describe all the steps necessary for secure acceptance of the delivered TOE in accordance with the developer's delivery

procedures.

AGD\_PRE.1.2C

The preparative procedures shall describe all the steps necessary for secure installation of the TOE and for the secure preparation of the operational environment in accordance with the security objectives for the operational environment as described in the ST.

**Evaluator action elements:**

AGD\_PRE.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

AGD\_PRE.1.2E

The evaluator shall apply the preparative procedures to confirm that the TOE can be prepared securely for operation.

### 5.2.3 Class ALC: Life-cycle Support

At the assurance level provided for TOEs conformant to this PP, life-cycle support is limited to end-user-visible aspects of the life-cycle, rather than an examination of the TOE vendor's development and configuration management process. This is not meant to diminish the critical role that a developer's practices play in contributing to the overall trustworthiness of a product; rather, it is a reflection on the information to be made available for evaluation at this assurance level.

#### ALC\_CMC.1 Labeling of the TOE (ALC\_CMC.1)

This component is targeted at identifying the TOE such that it can be distinguished from other products or versions from the same vendor and can be easily specified when being procured by an end user.

**Developer action elements:**

ALC\_CMC.1.1D

The developer shall provide the TOE and a reference for the TOE.

**Content and presentation elements:**

ALC\_CMC.1.1C

The application shall be labeled with a unique reference.

**Evaluator action elements:**

ALC\_CMC.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

### Evaluation Activities ▼

#### ALC\_CMC.1

*The evaluator will check the ST to ensure that it contains an identifier (such as a product name/version number) that specifically identifies the version that meets the requirements of the ST. Further, the evaluator will check the AGD guidance and QS samples received for testing to ensure that the version number is consistent with that in the ST. If the vendor maintains a web site*

advertising the QS, the evaluator will examine the information on the web site to ensure that the information in the ST is sufficient to distinguish the product.

## ALC\_CMS.1 TOE CM Coverage (ALC\_CMS.1)

### Developer action elements:

ALC\_CMS.1.1D

The developer shall provide a configuration list for the TOE.

### Content and presentation elements:

ALC\_CMS.1.1C

The configuration list shall include the following: the TOE itself; and the evaluation evidence required by the SARs.

ALC\_CMS.1.2C

The configuration list shall uniquely identify the configuration items.

### Evaluator action elements:

ALC\_CMS.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

## Evaluation Activities ▼

### ALC\_CMS.1

The "evaluation evidence required by the SARs" in this PP is limited to the information in the ST coupled with the guidance provided to administrators and users under the AGD requirements. By ensuring that the QS is specifically identified and that this identification is consistent in the ST and in the AGD guidance (as done in the assurance activity for ALC\_CMC.1), the evaluator implicitly confirms the information required by this component. Life-cycle support is targeted aspects of the developer's life-cycle and instructions to providers of applications for the developer's devices, rather than an in-depth examination of the TSE manufacturer's development and configuration management process. This is not meant to diminish the critical role that a developer's practices play in contributing to the overall trustworthiness of a product; rather, it's a reflection on the information to be made available for evaluation.

The evaluator will ensure that the developer has identified (in guidance documentation for application developers concerning the targeted platform) one or more development environments appropriate for use in developing applications for the developer's platform. For each of these development environments, the developer shall provide information on how to configure the environment to ensure that buffer overflow protection mechanisms in the environment(s) are invoked (e.g., compiler and linker flags). The evaluator will ensure that this documentation also includes an indication of whether such protections are on by default, or have to be specifically enabled. The evaluator will ensure that the TSE is uniquely identified (with respect to other products from the TSE vendor), and that documentation provided by the developer in association with the requirements in the ST is associated with the TSE using this unique identification.

## 5.2.4 Class ASE: ST Evaluation

As per ASE activities defined in [\[CEM\]](#).

## ASE\_CCL.1 Conformance Claims

### Developer action elements:

ASE\_CCL.1.1D

The developer shall provide a conformance claim.

ASE\_CCL.1.2D

The developer shall provide a conformance claim rationale.

### Content and presentation elements:

ASE\_CCL.1.1C

The conformance claim shall identify the edition of the ~~CC~~ to which the ~~ST~~ and the ~~TOE~~ claim conformance.

ASE\_CCL.1.2C

The conformance claim shall describe the conformance of the ~~ST~~ to ~~CC~~ Part 2 as either ~~CC~~ Part 2 conformant or ~~CC~~ Part 2 extended.

ASE\_CCL.1.3C

The conformance claim shall describe the conformance of the ~~ST~~ as either “~~CC~~ Part 3 conformant” or “~~CC~~ Part 3 extended”.

ASE\_CCL.1.4C

The conformance claim shall be consistent with the extended components definition.

ASE\_CCL.1.5C

The conformance claim shall identify a ~~PP-Configuration~~, or all ~~PPs~~ and security requirement packages to which the ~~ST~~ claims conformance.

ASE\_CCL.1.6C

The conformance claim shall describe any conformance of the ~~ST~~ to a package as either package-conformant or package-augmented.

ASE\_CCL.1.7C

The conformance claim shall describe any conformance of the ~~ST~~ to a ~~PP~~ as ~~PP~~-Conformant.

ASE\_CCL.1.8C

The conformance claim rationale shall demonstrate that the ~~TOE~~ type is consistent with the ~~TOE~~ type in the ~~PP-Configuration~~ or ~~PPs~~ for which conformance is being claimed.

ASE\_CCL.1.9C

The conformance claim rationale shall demonstrate that the statement of the security problem definition is consistent with the statement of the security problem definition in the ~~PP-Configuration~~, ~~PPs~~ and any functional packages for which conformance is being claimed.

ASE\_CCL.1.10C

The conformance claim rationale shall demonstrate that the statement of security objectives is consistent with the statement of security objectives in the ~~PP-Configuration~~, ~~PPs~~, and any functional package for which conformance is being claimed.

ASE\_CCL.1.11C



The conformance claim rationale shall demonstrate that the statement of security requirements is consistent with the statement of security requirements in the ~~PP-Configuration~~, ~~PPs~~, and any functional packages for which conformance is being claimed.

ASE\_CCL.1.12C

The conformance claim for ~~PP(s)~~ or a ~~PP-Configuration~~ shall be exact, strict, or demonstrable or a list of conformance types.

ASE\_CCL.1.13C

If the conformance claim identifies a set of Evaluation methods and Evaluation activities derived from ~~CEM~~ work units that shall be used to evaluate the ~~TOE~~ then this set shall include all those that are included in any package, ~~PP~~, or ~~PP-Module~~ in a ~~PP-Configuration~~ to which the ~~ST~~ claims conformance, and no others.

#### **Evaluator action elements:**

ASE\_CCL.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

### **ASE\_ECD.1 Extended Components Definition**

#### **Developer action elements:**

ASE\_ECD.1.1D

The developer shall provide a statement of security requirements.

ASE\_ECD.1.2D

The developer shall provide an extended components definition.

#### **Content and presentation elements:**

ASE\_ECD.1.1C

The statement of security requirements shall identify all extended security requirements.

ASE\_ECD.1.2C

The extended components definition shall define an extended component for each extended security requirement.

ASE\_ECD.1.3C

The extended components definition shall describe how each extended component is related to the existing ~~CC~~ components, families, and classes.

ASE\_ECD.1.4C

The extended components definition shall use the existing ~~CC~~ components, families, classes, and methodology as a model for presentation.

ASE\_ECD.1.5C

The extended components shall consist of measurable and objective elements such that conformance or nonconformance to these elements may be demonstrated.

#### **Evaluator action elements:**

ASE\_ECD.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ASE\_ECD.1.2E

The evaluator shall confirm that no extended component may be clearly expressed using existing components.

## **ASE\_INT.1 ST Introduction**

### **Developer action elements:**

ASE\_INT.1.1D

The developer shall provide an ST introduction.

### **Content and presentation elements:**

ASE\_INT.1.1C

The ST introduction shall contain an ST reference, a TOE reference, a TOE overview and a TOE description.

ASE\_INT.1.2C

The ST reference shall uniquely identify the ST.

ASE\_INT.1.3C

The TOE reference shall uniquely identify the TOE.

ASE\_INT.1.4C

The TOE overview shall summarize the usage and major security features of the TOE.

ASE\_INT.1.5C

The TOE overview shall identify the TOE type.

ASE\_INT.1.6C

The TOE overview shall identify any non-TOE hardware/software/firmware required by the TOE.

ASE\_INT.1.7C

For a multi-assurance ST, the TOE overview shall describe the TSF organization in terms of the sub-TSFs defined in the PP-Configuration the ST claims conformance to.

ASE\_INT.1.8C

The TOE description shall describe the physical scope of the TOE.

ASE\_INT.1.9C

The TOE description shall describe the logical scope of the TOE.

### **Evaluator action elements:**

ASE\_INT.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ASE\_INT.1.2E

The evaluator shall confirm that the TOE reference, the TOE overview, and the TOE description are consistent with each other.

## **ASE\_OBJ.1 ST Objectives for the Operational Environment**

### **Developer action elements:**

ASE\_OBJ.1.1D

The developer shall provide a statement of security objectives for the operational environment.

ASE\_OBJ.1.2D

The developer shall provide a security objectives rationale for the operational environment.

### **Content and presentation elements:**

ASE\_OBJ.1.1C

The statement of security objectives shall describe the security objectives for the operational environment.

ASE\_OBJ.1.2C

The security objectives rationale shall trace each security objective for the operational environment back to threats countered by that security objective, OSPs enforced by that security objective, and assumptions upheld by that security objective.

ASE\_OBJ.1.3C

The security objectives rationale shall demonstrate that the security objectives for the operational environment uphold all assumptions.

### **Evaluator action elements:**

ASE\_OBJ.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

## **ASE\_REQ.1 Stated Security Requirements**

### **Developer action elements:**

ASE\_REQ.1.1D

The developer shall provide a statement of security requirements.

ASE\_REQ.1.2D

The developer shall provide a security requirements rationale.

### **Content and presentation elements:**

ASE\_REQ.1.1C

The statement of security requirements shall describe the ~~SFRs~~ and the ~~SARs~~.

ASE\_REQ.1.2C

For a single-assurance ~~ST~~, the statement of security requirements shall define the global set of ~~SARs~~ that apply to the entire ~~TOE~~. The sets of ~~SARs~~ shall be consistent with the ~~PPs~~ or ~~PP-Configuration~~ to which the ~~ST~~ claims conformance.

ASE\_REQ.1.3C

For a multi-assurance ~~ST~~, the statement of security requirements shall define the global set of ~~SARs~~ that apply to the entire ~~TOE~~ and the sets of ~~SARs~~ that apply to

each sub-TSF. The sets of SARs shall be consistent with the multi-assurance PP-Configuration to which the ST claims conformance.

ASE\_REQ.1.4C

All subjects, objects, operations, security attributes, external entities and other terms that are used in the SERs and the SARs shall be defined.

ASE\_REQ.1.5C

The statement of security requirements shall identify all operations on the security requirements.

ASE\_REQ.1.6C

All operations shall be performed correctly.

ASE\_REQ.1.7C

Each dependency of the security requirements shall either be satisfied, or the security requirements rationale shall justify the dependency not being satisfied.

ASE\_REQ.1.8C

The security requirements rationale shall demonstrate that the SERs (in conjunction with the security objectives for the environment) counter all threats for the TOE.

ASE\_REQ.1.9C

The security requirements rationale shall demonstrate that the SERs (in conjunction with the security objectives for the environment) enforce all OSPs.

ASE\_REQ.1.10C

The security requirements rationale shall explain why the SARs were chosen.

ASE\_REQ.1.11C

The statement of security requirements shall be internally consistent.

ASE\_REQ.1.12C

If the ST defines sets of SARs that expand the sets of SARs of the PPs or PP-Configuration it claims conformance to, the security requirements rationale shall include an assurance rationale that justifies the consistency of the extension and provides a rationale for the disposition of any Evaluation methods and Evaluation activities identified in the conformance statement that are affected by the extension of the sets of SARs

**Evaluator action elements:**

ASE\_REQ.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

**ASE\_TSS.1 TOE Summary Specification**

**Developer action elements:**

ASE\_TSS.1.1D

The developer shall provide a TOE summary specification.

**Content and presentation elements:**

ASE\_TSS.1.1C

The TOE summary specification shall describe how the TOE meets each SER.

## Evaluator action elements:

ASE\_TSS.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ASE\_TSS.1.2E

The evaluator shall confirm that the TOE summary specification is consistent with the TOE overview and the TOE description.

## 5.2.5 Class ATE: Tests

Testing is specified for functional aspects of the system as well as aspects that take advantage of design or implementation weaknesses. The former is done through the ATE\_IND family, while the latter is through the AVA\_VAN family. At the assurance level specified in this PP, testing is based on advertised functionality and interfaces with dependency on the availability of design information. One of the primary outputs of the evaluation process is the test report as specified in the following requirements.

### ATE\_IND.1 Independent Testing – Conformance (ATE\_IND.1)

Testing is performed to confirm the functionality described in the TSS as well as the administrative (including configuration and operational) documentation provided. The focus of the testing is to confirm that the requirements specified in [Section 5.1 Security Functional Requirements](#) being met, although some additional testing is specified for SARs in [Section 5.2 Security Assurance Requirements](#). The evaluation activities identify the additional testing activities associated with these components. The evaluator produces a test report documenting the plan for and results of testing, as well as coverage arguments focused on the platform/TOE combinations that are claiming conformance to this PP. Given the scope of the TOE and its associated evaluation evidence requirements, this component's evaluation activities are covered by the evaluation activities listed for [ALC\\_CMC.1](#).

## Developer action elements:

ATE\_IND.1.1D

The developer shall provide the TOE for testing.

## Content and presentation elements:

ATE\_IND.1.1C

The TOE shall be suitable for testing.

## Evaluator action elements:

ATE\_IND.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ATE\_IND.1.2E

The evaluator shall test a subset of the TSE to confirm that the TSE operates as specified.

**Application Note:** The evaluator will test the QS on the most current fully patched version of the platform.

## Evaluation Activities ▼

#### **ATE\_IND.1**

*The evaluator will prepare a test plan and report documenting the testing aspects of the system, including any application crashes during testing. The evaluator shall determine the root cause of any application crashes and include that information in the report. The test plan covers all of the testing actions contained in the [CEM] and the body of this P.P.'s Assurance Activities.*

*While it is not necessary to have one test case per test listed in an Assurance Activity, the evaluator must document in the test plan that each applicable testing requirement in the S.T. is covered. The test plan identifies the platforms to be tested, and for those platforms not included in the test plan but included in the S.T., the test plan provides a justification for not testing the platforms. This justification must address the differences between the tested platforms and the untested platforms, and make an argument that the differences do not affect the testing to be performed. It is not sufficient to merely assert that the differences have no affect; rationale must be provided. If all platforms claimed in the S.T. are tested, then no rationale is necessary. The test plan describes the composition of each platform to be tested, and any setup that is necessary beyond what is contained in the AGD documentation. It should be noted that the evaluator is expected to follow the AGD documentation for installation and setup of each platform either as part of a test or as a standard pre-test condition. This may include special test drivers or tools. For each driver or tool, an argument (not just an assertion) should be provided that the driver or tool will not adversely affect the performance of the functionality by the Q.S. and its platform.*

*This also includes the configuration of the cryptographic engine to be used. The cryptographic algorithms implemented by this engine are those specified by this P.P. and used by the cryptographic protocols being evaluated (IPsec, TLS). The test plan identifies high-level test objectives as well as the test procedures to be followed to achieve those objectives. These procedures include expected results.*

*The test report (which could just be an annotated version of the test plan) details the activities that took place when the test procedures were executed, and includes the actual results of the tests. This shall be a cumulative account, so if there was a test run that resulted in a failure; a fix installed; and then a successful re-run of the test, the report would show a "fail" and "pass" result (and the supporting details), and not just the "pass" result.*

### **5.2.6 Class AVA: Vulnerability Assessment**

For the current generation of this protection profile, the evaluation lab is expected to survey open sources to discover what vulnerabilities have been discovered in these types of products. In most cases, these vulnerabilities will require sophistication beyond that of a basic attacker. Until penetration tools are created and uniformly distributed to the evaluation labs, the evaluator will not be expected to test for these vulnerabilities in the T.O.E. The labs will be expected to comment on the likelihood of these vulnerabilities given the documentation provided by the vendor. This information will be used in the development of penetration testing tools and for the development of future protection profiles.

#### **AVA\_VAN.1 Vulnerability Survey (AVA\_VAN.1)**

##### **Developer action elements:**

AVA\_VAN.1.1D

The developer shall provide the T.O.E. for testing.

##### **Content and presentation elements:**

AVA\_VAN.1.1C

The T.O.E. shall be suitable for testing.

##### **Evaluator action elements:**

AVA\_VAN.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

AVA\_VAN.1.2E

The evaluator shall perform a search of public domain sources to identify potential vulnerabilities in the ~~TOE~~.

AVA\_VAN.1.3E

The evaluator shall conduct penetration testing, based on the identified potential vulnerabilities, to determine that the ~~TOE~~ is resistant to attacks performed by an attacker possessing Basic attack potential.

# Appendix A - Optional Requirements

As indicated in the introduction to this PP, the baseline requirements (those that must be performed by the TOE) are contained in the body of this PP. This appendix contains three other types of optional requirements:

The first type, defined in Appendix A.1 Strictly Optional Requirements, are strictly optional requirements. If the TOE meets any of these requirements the vendor is encouraged to claim the associated SERs in the ST, but doing so is not required in order to conform to this PP.

The second type, defined in Appendix A.2 Objective Requirements, are objective requirements. These describe security functionality that is not yet widely available in commercial technology. Objective requirements are not currently mandated by this PP, but will be mandated in the future. Adoption by vendors is encouraged, but claiming these SERs is not required in order to conform to this PP.

The third type, defined in Appendix A.3 Implementation-dependent Requirements, are Implementation-dependent requirements. If the TOE implements the product features associated with the listed SERs, either the SERs must be claimed or the product features must be disabled in the evaluated configuration.

## A.1 Strictly Optional Requirements

### A.1.1 Class ALC: Life-cycle Support

#### ALC\_FLR.1 Basic Flaw Remediation (ALC\_FLR.1)

*This SAR is optional and may be claimed at the ST-Author's discretion.*

#### Developer action elements:

ALC\_FLR.1.1D                      The developer shall document and provide flaw remediation procedures addressed to TOE developers.

#### Content and presentation elements:

ALC\_FLR.1.1C                      The flaw remediation procedures documentation shall describe the procedures used to track all reported security flaws in each release of the TOE.

ALC\_FLR.1.2C                      The flaw remediation procedures shall require that a description of the nature and effect of each security flaw be provided, as well as the status of finding a correction to that flaw.

ALC\_FLR.1.3C                      The flaw remediation procedures shall require that corrective actions be identified for each of the security flaws.



ALC\_FLR.1.4C

The flaw remediation procedures documentation shall describe the methods used to provide flaw information, corrections and guidance on corrective actions to TOE users.

**Evaluator action elements:**

ALC\_FLR.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

**ALC\_FLR.2 Flaw Reporting Procedures (ALC\_FLR.2)**

*This SAR is optional and may be claimed at the ST-Author's discretion.*

**Developer action elements:**

ALC\_FLR.2.1D

The developer shall document and provide flaw remediation procedures addressed to TOE developers.

ALC\_FLR.2.2D

The developer shall establish a procedure for accepting and acting upon all reports of security flaws and requests for corrections to those flaws.

ALC\_FLR.2.3D

The developer shall provide flaw remediation guidance addressed to TOE users.

**Content and presentation elements:**

ALC\_FLR.2.1C

The flaw remediation procedures documentation shall describe the procedures used to track all reported security flaws in each release of the TOE.

ALC\_FLR.2.2C

The flaw remediation procedures shall require that a description of the nature and effect of each security flaw be provided, as well as the status of finding a correction to that flaw.

ALC\_FLR.2.3C

The flaw remediation procedures shall require that corrective actions be identified for each of the security flaws.

ALC\_FLR.2.4C

The flaw remediation procedures documentation shall describe the methods used to provide flaw information, corrections and guidance on corrective actions to TOE users.

ALC\_FLR.2.5C

The flaw remediation procedures shall describe a means by which the developer receives from TOE users reports and enquiries of suspected security flaws in the TOE.

ALC\_FLR.2.6C

The procedures for processing reported security flaws shall ensure that any reported flaws are remediated and the remediation procedures issued to TOE users.

ALC\_FLR.2.7C

The procedures for processing reported security flaws shall provide safeguards that any corrections to these security flaws do not introduce any new flaws.

ALC\_FLR.2.8C

The flaw remediation guidance shall describe a means by which TOE users report to the developer any suspected security flaws in the TOE.

**Evaluator action elements:**

ALC\_FLR.2.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

**ALC\_FLR.3 Systematic Flaw Remediation (ALC\_FLR.3)**

*This SAR is optional and may be claimed at the ST-Author's discretion.*

**Developer action elements:**

ALC\_FLR.3.1D

The developer shall document and provide flaw remediation procedures addressed to TOE developers.

ALC\_FLR.3.2D

The developer shall establish a procedure for accepting and acting upon all reports of security flaws and requests for corrections to those flaws.

ALC\_FLR.3.3D

The developer shall provide flaw remediation guidance addressed to TOE users.

**Content and presentation elements:**

ALC\_FLR.3.1C

The flaw remediation procedures documentation shall describe the procedures used to track all reported security flaws in each release of the TOE.

ALC\_FLR.3.2C

The flaw remediation procedures shall require that a description of the nature and effect of each security flaw be provided, as well as the status of finding a correction to that flaw.

ALC\_FLR.3.3C

The flaw remediation procedures shall require that corrective actions be identified for each of the security flaws.

ALC\_FLR.3.4C

The flaw remediation procedures documentation shall describe the methods used to provide flaw information, corrections and guidance on corrective actions to TOE users.

ALC\_FLR.3.5C

The flaw remediation procedures shall describe a means by which the developer receives from ~~TOE~~ users reports and enquiries of suspected security flaws in the ~~TOE~~.

ALC\_FLR.3.6C

The flaw remediation procedures shall include a procedure requiring timely response and the automatic distribution of security flaw reports and the associated corrections to registered users who might be affected by the security flaw.

ALC\_FLR.3.7C

The procedures for processing reported security flaws shall ensure that any reported flaws are remediated and the remediation procedures issued to ~~TOE~~ users.

ALC\_FLR.3.8C

The procedures for processing reported security flaws shall provide safeguards that any corrections to these security flaws do not introduce any new flaws.

ALC\_FLR.3.9C

The flaw remediation guidance shall describe a means by which ~~TOE~~ users report to the developer any suspected security flaws in the ~~TOE~~.

ALC\_FLR.3.10C

The flaw remediation guidance shall describe a means by which ~~TOE~~ users may register with the developer, to be eligible to receive security flaw reports and corrections.

ALC\_FLR.3.11C

The flaw remediation guidance shall identify the specific points of contact for all reports and enquiries about security issues involving the ~~TOE~~.

### **Evaluator action elements:**

ALC\_FLR.3.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

### **ALC\_TSU\_EXT.1 Timely Security Updates**

*This ~~SAR~~ is optional and may be claimed at the ~~ST~~-Author's discretion.*

This component requires the ~~TOE~~ developer, in conjunction with any other necessary parties, to provide information as to how the end-user devices are updated to address security issues in a timely manner. The documentation describes the process of providing updates to the public from the time a security flaw is reported/discovered, to the time an update is released. This description includes the parties involved (e.g., the developer, carriers(s)) and the steps that are performed (e.g., developer testing, carrier testing), including worst case time periods, before an update is made available to the public.

### **Developer action elements:**

ALC\_TSU\_EXT.1.1D

The developer shall provide a description in the ~~TSS~~ of how timely security updates are made to the ~~TOE~~.

ALC\_TSU\_EXT.1.2D

The developer shall provide a description in the TSS of how users are notified when updates change security properties or the configuration of the product.

### Content and presentation elements:

#### ALC\_TSU\_EXT.1.1C

The description shall include the process for creating and deploying security updates for the TOE software.

#### ALC\_TSU\_EXT.1.2C

The description shall express the time window as the length of time, in days, between public disclosure of a vulnerability and the public availability of security updates to the TOE.

#### ALC\_TSU\_EXT.1.3C

The description shall include the mechanisms publicly available for reporting security issues pertaining to the TOE.

### Evaluator action elements:

#### ALC\_TSU\_EXT.1.1E

The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

### Evaluation Activities ▼

#### [ALC\\_TSU\\_EXT.1](#)

*The evaluator will verify that the TSS contains a description of the timely security update process used by the developer to create and deploy security updates. The evaluator will verify that this description addresses the entire application. The evaluator will also verify that, in addition to the QS developer's process, any third-party processes are also addressed in the description. The evaluator will also verify that each mechanism for deployment of security updates is described.*

*The evaluator will verify that, for each deployment mechanism described for the update process, the TSS lists a time between public disclosure of a vulnerability and public availability of the security update to the QS patching this vulnerability, to include any third-party or carrier delays in deployment. The evaluator will verify that this time is expressed in a number or range of days.*

*The evaluator will verify that this description includes the publicly available mechanisms (including either an email address or website) for reporting security issues related to the QS. The evaluator shall verify that the description of this mechanism includes a method for protecting the report either using a public key for encrypting email or a trusted channel for a website.*

## A.1.2 Security Audit (FAU)

### FAU\_STG.2 Protected Audit Data Storage

#### FAU\_STG.2.1

The TOE shall

### Evaluation Activities ▼

#### [FAU\\_STG.2](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**FAU\_STG\_EXT.2 Counting Lost Audit Data**

FAU\_STG\_EXT.2.1

The TOE shall

**Evaluation Activities** ▼

[FAU\\_STG\\_EXT.2](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**FAU\_STG\_EXT.3 Action in Case of Possible Audit Data Loss**

FAU\_STG\_EXT.3.1

The TOE shall

**Evaluation Activities** ▼

[FAU\\_STG\\_EXT.3](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

**A.1.3 Communication (FCO)**

## FCO\_CPC\_EXT.1 Component Registration Channel Definition

FCO\_CPC\_EXT.1.1

The ~~T.O.E~~ shall

FCO\_CPC\_EXT.1.2

The ~~T.O.E~~ shall

FCO\_CPC\_EXT.1.3

The ~~T.O.E~~ shall

### Evaluation Activities ▼

*FCO\_CPC\_EXT.1*

*Something*

~~T.S.S~~

*ABC*

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

## A.1.4 Cryptographic Support (FCS)

### FCS\_CKM.2 Cryptographic Key Distribution

FCS\_CKM.2.1

The ~~T.S.F~~ shall

## A.1.5 Protection of the TSF (FPT)

### FPT\_ITT.1 Basic internal TSF data transfer protection (Refinement)

FPT\_ITT.1.1

The ~~T.O.E~~ shall

### Evaluation Activities ▼

*FPT\_ITT.1*

*Something*

~~T.S.S~~

*ABC*

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

A.1.6 Trusted Channel (FTP\_ITC)

FTP\_TRP.1/Join Trusted Path (Refinement)

FTP\_TRP.1.1/Join  
The T\_OE shall

Evaluation Activities ▼

FTP\_TRP.1/Join  
Something  
TSS  
ABC

**Guidance**  
*There are no additional Guidance evaluation activities for this component.*

**Tests**  
*There are no test activities for this component.*

A.2 Objective Requirements

---

This PP does not define any Objective requirements.

A.3 Implementation-dependent Requirements

---

This PP does not define any Implementation-dependent requirements.

# Appendix B - Selection-based Requirements

As indicated in the introduction to this PP, the baseline requirements (those that must be performed by the TOE or its underlying platform) are contained in the body of this PP. There are additional requirements based on selections in the body of the PP: if certain selections are made, then additional requirements below must be included.

## B.1 Security Audit (FAU)

### FAU\_GEN\_EXT.1 Security Audit Generation

FAU\_GEN\_EXT.1.1      The TOE shall

#### Evaluation Activities ▼

*FAU\_GEN\_EXT.1*  
*Something*  
*TSS*  
*ABC*

**Guidance**  
*There are no additional Guidance evaluation activities for this component.*

**Tests**  
*There are no test activities for this component.*

### FAU\_SAR.1 Audit Review

*This component must be included in the ST if any of the following SFRs are included:*

- *FAU\_STG\_EXT.1*

FAU\_SAR.1.1      The TSF shall

### FAU\_STG\_EXT.4 Protected Local Audit Event Storage for Distributed TOEs

FAU\_STG\_EXT.4.1      The TOE shall



## Evaluation Activities ▼

[FAU\\_STG\\_EXT.4](#)

Something

~~TSS~~

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FAU\_STG\_EXT.5 Protected Remote Audit Event Storage for Distributed TOEs

FAU\_STG\_EXT.5.1

The ~~TOE~~ shall

## Evaluation Activities ▼

[FAU\\_STG\\_EXT.5](#)

Something

~~TSS~~

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## B.2 Cryptographic Support (FCS)

### FCS\_COP.1/AEAD Cryptographic Operation - Authenticated Encryption with Associated Data

*This component must be included in the ~~ST~~ if any of the following ~~SERs~~ are included:*

- [FCS\\_COP.1/DataEncryption](#)

FCS\_COP.1.1/AEAD

The ~~TSE~~ shall

## FCS\_COP.1/CMAC Cryptographic Operation - CMAC

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_NTP\\_EXT.1](#)

FCS\_COP.1.1/CMAC

The TSF shall

## FCS\_COP.1/KeyEncap Cryptographic Operation - Key Encapsulation

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_CKM.2](#)

FCS\_COP.1.1/KeyEncap

The TSF shall

## FCS\_COP.1/KeyWrap Cryptographic Operation - Key Wrapping

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_CKM.2](#)

FCS\_COP.1.1/KeyWrap

The TSF shall

## FCS\_COP.1/SKC Cryptographic Operation - Symmetric Key Cryptography

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_COP.1/DataEncryption](#)

FCS\_COP.1.1/SKC

The TSF shall

## FCS\_COP.1/XOF Cryptographic Operation - Extendable-Output Function

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_COP.1/SigVer](#)

FCS\_COP.1.1/XOF

The TSF shall perform *extendable-output function* in accordance with a specified cryptographic algorithm

[**selection:** *Cryptographic Algorithm*] and [**selection:** *Parameters*] that meet the following: [**selection:** *List of Standards*]. The following table provides the allowed

choices for completion of the selection operations of [FCS\\_COP.1.1/XOF](#).

**Table 3: Allowed choices for [FCS\\_COP.1.1/XOF](#)**

| Cryptographic Algorithm | Parameters                       | List of Standards               |
|-------------------------|----------------------------------|---------------------------------|
| SHAKE                   | Functions = [SHAKE128, SHAKE256] | NIST FIPS PUB 202 (Section 6.2) |

**Application Note:** Since LMS and XMSS use both SHAKE128 and SHAKE256 internally, claiming and testing of both Functions is mandatory

**FCS\_IPSEC\_EXT.1 IPsec Protocol**

- FCS\_IPSEC\_EXT.1.1  
The TOE shall
- FCS\_IPSEC\_EXT.1.2  
The TSF shall
- FCS\_IPSEC\_EXT.1.3  
The TSF shall
- FCS\_IPSEC\_EXT.1.4  
The TSF shall
- FCS\_IPSEC\_EXT.1.5  
The TSF shall
- FCS\_IPSEC\_EXT.1.6  
The TSF shall
- FCS\_IPSEC\_EXT.1.7  
The TSF shall
- FCS\_IPSEC\_EXT.1.8  
The TSF shall
- FCS\_IPSEC\_EXT.1.9  
The TSF shall
- FCS\_IPSEC\_EXT.1.10  
The TSF shall
- FCS\_IPSEC\_EXT.1.11  
The TSF shall
- FCS\_IPSEC\_EXT.1.12  
The TSF shall
- FCS\_IPSEC\_EXT.1.13  
The TSF shall
- FCS\_IPSEC\_EXT.1.14

The ~~T.SF~~ shall

## Evaluation Activities ▼

[FCS\\_IPSEC\\_EXT.1](#)

Something

~~TSS~~

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FCS\_NTP\_EXT.1 NTP Protocol

FCS\_NTP\_EXT.1.1

The ~~T.OF~~ shall

## Evaluation Activities ▼

[FCS\\_NTP\\_EXT.1](#)

Something

~~TSS~~

ABC

### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

### **Tests**

*There are no test activities for this component.*

## FCS\_RBG.2 Random Bit Generation (External Seeding)

*This component must be included in the ~~ST~~ if any of the following ~~SERs~~ are included:*

- [FCS\\_RBG.1](#)

FCS\_RBG.2.1

The ~~T.SF~~ shall

## FCS\_RBG.3 Random Bit Generation (Internal Seeding - Single Source)

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_RBG.1](#)

#### FCS\_RBG.3.1

The TSF shall be able to seed the DRBG using a [selection, choose one of: TSF software-based entropy source, TSF hardware-based entropy source] [assignment: name of entropy source] with [assignment: number of bits] bits of min-entropy.

**Application Note:** This requirement is claimed when a TOE uses a single internal source of entropy to initialize or reseed a DRBG that is within the TOE boundary. Seeding a DRBG is the same as initializing a DRBG.

Hardware-based noise sources are entropy sources whose primary function is noise generation, such as ring oscillators, diodes, and thermal noise. While a TOE may use software to collect the noise from these hardware sources, these are not software-based.

Software-based noise sources generate noise as a byproduct of their normal operation. Examples of software-based noise sources can be user or system-based events such as reading the least significant bits from an event timer, etc.

The TOE collects enough input from the internal noise source such that the total measured entropy of the input is sufficient to initialize or reseed a DRBG. The ST author ensures that the assignment is completed with the number of bits of the input sufficient to initialize or reseed a DRBG.

#### FCS\_RBG.4 Random Bit Generation (Internal Seeding - Multiple Sources)

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_RBG.1](#)

#### FCS\_RBG.4.1

The TSF shall be able to seed the DRBG using [selection: [assignment: number] TSF software-based entropy source(s), [assignment: number] TSF hardware-based entropy source(s)].

**Application Note:** This requirement is claimed when a TOE uses two or more internal sources of entropy to initialize or reseed a DRBG. Seeding a DRBG is the same as initializing a DRBG. [FCS\\_RBG.5](#) defines the mechanism by which these sources are combined to ensure sufficient minimum entropy.

#### FCS\_RBG.5 Random Bit Generation (Combining Entropy Sources)

*This component must be included in the ST if any of the following SFRs are included:*

- [FCS\\_RBG.1](#)

#### FCS\_RBG.5.1

TSF shall [selection: hash, concatenate and hash, XOR, input into a linear feedback shift register, [assignment: combining operation]] [selection: output from TSF entropy source(s), input from TSF interface(s) for obtaining entropy] resulting in a

minimum of [**assignment:** *number of bits*] bits of min-entropy to create the entropy input into the derivation function as defined in [**selection:** *ISO/IEC 18031:2011, NIST SP 800-90A Revision 1*].

**Application Note:** This requirement is claimed when a **TOE** combines two or more sources of entropy to initialize or reseed a **DRBG**. Seeding a **DRBG** is the same as initializing a **DRBG**. The **ST** author ensures that the assignment is completed with the number of bits of the combined entropy sufficient to initialize or reseed a **DRBG**. One can apply NIST SP 800-90B (or AIS-31) statistical tests against internal noise sources (a.k.a. raw entropy) to confirm the min-entropy of the noise sources either in aggregate or individually. One should not apply NIST SP 800-90B (or AIS-31) statistical tests against external noise sources since the **TOE** is unable to enforce entropy requirements or conditioning requirements against external sources of entropy. However, the **TSS** may include estimates for min-entropy from external sources that contribute to the overall entropy requirements for the **DRBG**.

## B.3 Security Management (FMT)

### FMT\_MOF.1/AutoUpdate Management of Security Functions Behaviour

FMT\_MOF.1.1/AutoUpdate

The **TOE** shall

#### Evaluation Activities ▼

*FMT\_MOF.1/AutoUpdate*

*Something*

**TSS**

*ABC*

#### **Guidance**

*There are no additional Guidance evaluation activities for this component.*

#### **Tests**

*There are no test activities for this component.*

### FMT\_MOF.1/Functions Management of Security Functions Behaviour

FMT\_MOF.1.1/Functions

The **TOE** shall

#### Evaluation Activities ▼

*FMT\_MOF.1/Functions*

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

## FMT\_MOF.1/Services Management of Security Functions Behaviour

FMT\_MOF.1.1/Services

The TOE shall

### Evaluation Activities ▼

[FMT\\_MOF.1/Services](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

## FMT\_MTD.1/CryptoKeys Management of TSF Data

FMT\_MTD.1.1/CryptoKeys

The TOE shall

### Evaluation Activities ▼

[FMT\\_MTD.1/CryptoKeys](#)

Something

**TSS**

ABC

**Guidance**

*There are no additional Guidance evaluation activities for this component.*

**Tests**

*There are no test activities for this component.*

## B.4 Protection of the TSF (FPT)

---

### FPT\_TUD\_EXT.2 Trusted Update Based on Certificates

FPT\_TUD\_EXT.2.1

The TOE shall

#### Evaluation Activities ▼

[\*FPT\\_TUD\\_EXT.2\*](#)

*Something*

***TSS***

*ABC*

#### ***Guidance***

*There are no additional Guidance evaluation activities for this component.*

#### ***Tests***

*There are no test activities for this component.*



# Appendix C - Entropy Documentation and Assessment

blah

# Appendix D - Glossary

## D.1 Terms

---

The following sections list Common Criteria and technology terms used in this document.

### D.1.1 Common Criteria Terms

|                                        |                                                                                                                                                                                                                                                                                             |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Assurance                              | Grounds for confidence that a TOE meets the SFRs <a href="#">[CC]</a> .                                                                                                                                                                                                                     |
| Base Protection Profile (Base-PP)      | Protection Profile used as a basis to build a PP-Configuration.                                                                                                                                                                                                                             |
| Collaborative Protection Profile (cPP) | A Protection Profile developed by international technical communities and approved by multiple schemes.                                                                                                                                                                                     |
| Common Criteria (CC)                   | Common Criteria for Information Technology Security Evaluation (International Standard ISO/IEC 15408).                                                                                                                                                                                      |
| Common Criteria Testing Laboratory     | Within the context of the Common Criteria Evaluation and Validation Scheme (CCEVS), an IT security evaluation facility accredited by the National Voluntary Laboratory Accreditation Program (NVLAP) and approved by the NIAP Validation Body to conduct Common Criteria-based evaluations. |
| Common Evaluation Methodology (CEM)    | Common Evaluation Methodology for Information Technology Security Evaluation.                                                                                                                                                                                                               |
| Direct Rationale                       | A type of Protection Profile, PP-Module, or Security Target in which the security problem definition (SPD) elements are mapped directly to the SFRs and possibly to the security objectives for the operational environment. There are no security objectives for the TOE.                  |
| Distributed TOE                        | A TOE composed of multiple components operating as a logical whole.                                                                                                                                                                                                                         |
| Extended Package (EP)                  | A deprecated document form for collecting SFRs that implement a particular protocol, technology, or functionality. See Functional Packages.                                                                                                                                                 |
| Functional Package (FP)                | A document that collects SFRs for a particular protocol, technology, or functionality.                                                                                                                                                                                                      |
| Operational Environment (OE)           | Hardware and software that are outside the TOE boundary that support the TOE functionality and security policy.                                                                                                                                                                             |
| Protection Profile (PP)                | An implementation-independent set of security requirements for a category of products.                                                                                                                                                                                                      |

|                                                     |                                                                                                                                   |
|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Protection Profile Configuration (PP-Configuration) | A comprehensive set of security requirements for a product type that consists of at least one Base-PP and at least one PP-Module. |
| Protection Profile Module (PP-Module)               | An implementation-independent statement of security needs for a TOE type complementary to one or more Base-PPs.                   |
| Security Assurance Requirement (SAR)                | A requirement to assure the security of the TOE.                                                                                  |
| Security Functional Requirement (SFR)               | A requirement for security enforcement by the TOE.                                                                                |
| Security Target (ST)                                | A set of implementation-dependent security requirements for a specific product.                                                   |
| Target of Evaluation (TOE)                          | The product under evaluation.                                                                                                     |
| TOE Security Functionality (TSF)                    | The security functionality of the product under evaluation.                                                                       |
| TOE Summary Specification (TSS)                     | A description of how a TOE satisfies the SFRs in an ST.                                                                           |

### D.1.2 Technical Terms

|                                           |                                                                                                                                                                                                                                                                                                                                                                                              |
|-------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Address Space Layout Randomization (ASLR) | An anti-exploitation feature which loads memory mappings into unpredictable locations. ASLR makes it more difficult for an attacker to redirect control to code that they have introduced into the address space of a process.                                                                                                                                                               |
| Administrator                             | An administrator is responsible for management activities, including setting policies that are applied by the enterprise on the operating system. This administrator could be acting remotely through a management server, from which the system receives configuration policies. An administrator can enforce settings on the system which cannot be overridden by non-administrator users. |
| Application (app)                         | Software that runs on a platform and performs tasks on behalf of the user or owner of the platform, as well as its supporting documentation.                                                                                                                                                                                                                                                 |
| Application Programming Interface (API)   | A specification of routines, data structures, object classes, and variables that allows an application to make use of services provided by another software component, such as a library. APIs are often provided for a set of libraries included with the platform.                                                                                                                         |
| Credential                                | Data that establishes the identity of a user, e.g. a cryptographic key or password.                                                                                                                                                                                                                                                                                                          |
| Critical Security Parameters (CSP)        | Information that is either user or system defined and is used to operate a cryptographic module in processing encryption functions including cryptographic keys and authentication data, such as passwords, the disclosure or modification of which can compromise the security of a cryptographic module or the security of the information protected by the module.                        |
| DAR Protection                            | Countermeasures that prevent attackers, even those with physical access, from extracting data from non-volatile storage. Common techniques include data encryption and wiping.                                                                                                                                                                                                               |

|                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|-------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data Execution Prevention (DEP)           | An anti-exploitation feature of modern operating systems executing on modern computer hardware, which enforces a non-execute permission on pages of memory. DEP prevents pages of memory from containing both data and instructions, which makes it more difficult for an attacker to introduce and execute code.                                                                                                                                                                                            |
| Developer                                 | An entity that writes OS software. For the purposes of this document, vendors and developers are the same.                                                                                                                                                                                                                                                                                                                                                                                                   |
| General Purpose Operating System          | A class of OSES designed to support a wide-variety of workloads consisting of many concurrent applications or services. Typical characteristics for OSES in this class include support for third-party applications, support for multiple users, and security separation between users and their respective resources. General Purpose Operating Systems also lack the real-time constraint that defines Real Time Operating Systems (RTOS). RTOSes typically power routers, switches, and embedded devices. |
| Host-based Firewall                       | A software-based firewall implementation running on the OS for filtering inbound and outbound network traffic to and from processes running on the OS.                                                                                                                                                                                                                                                                                                                                                       |
| Operating System (OS)                     | Software that manages physical and logical resources and provides services for applications. The terms <i>TOE</i> and <i>OS</i> are interchangeable in this document.                                                                                                                                                                                                                                                                                                                                        |
| Personally Identifiable Information (PII) | Any information about an individual maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and information which can be used to distinguish or trace an individual's identity, such as their name, social security number, date and place of birth, mother's maiden name, biometric records, etc., including any other personal information which is linked or linkable to an individual. <a href="#">[OMB]</a>      |
| Sensitive Data                            | Sensitive data may include all user or enterprise data or may be specific application data such as PII, emails, messaging, documents, calendar items, and contacts. Sensitive data must minimally include credentials and keys. Sensitive data shall be identified in the OS's TSS by the ST author.                                                                                                                                                                                                         |
| User                                      | A user is subject to configuration policies applied to the operating system by administrators. On some systems under certain configurations, a normal user can temporarily elevate privileges to that of an administrator. At that time, such a user should be considered an administrator.                                                                                                                                                                                                                  |
| Virtual Machine (VM)                      | Blah Blah Blah                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

# Appendix E - Acronyms

Table 4: Acronyms

| Acronym | Meaning                                   |
|---------|-------------------------------------------|
| AES     | Advanced Encryption Standard              |
| API     | Application Programming Interface         |
| API     | Application Programming Interface         |
| app     | Application                               |
| ASLR    | Address Space Layout Randomization        |
| Base-PP | Base Protection Profile                   |
| CC      | Common Criteria                           |
| CEM     | Common Evaluation Methodology             |
| CESG    | Communications-Electronics Security Group |
| CMC     | Certificate Management over CMS           |
| CMS     | Cryptographic Message Syntax              |
| CN      | Common Names                              |
| cPP     | Collaborative Protection Profile          |
| CRL     | Certificate Revocation List               |
| CSA     | Computer Security Act                     |
| CSP     | Critical Security Parameters              |
| DAR     | Data At Rest                              |
| DEP     | Data Execution Prevention                 |
| DES     | Data Encryption Standard                  |
| DHE     | Diffie-Hellman Ephemeral                  |
| DNS     | Domain Name System                        |
| DRBG    | Deterministic Random Bit Generator        |
| DSS     | Digital Signature Standard                |

|       |                                                     |
|-------|-----------------------------------------------------|
| DSS   | Digital Signature Standard                          |
| DT    | Date/Time Vector                                    |
| DTLS  | Datagram Transport Layer Security                   |
| EAP   | Extensible Authentication Protocol                  |
| ECDHE | Elliptic Curve Diffie-Hellman Ephemeral             |
| ECDSA | Elliptic Curve Digital Signature Algorithm          |
| EP    | Extended Package                                    |
| EST   | Enrollment over Secure Transport                    |
| FIPS  | Federal Information Processing Standards            |
| FP    | Functional Package                                  |
| HMAC  | Hash-based Message Authentication Code              |
| HTTP  | Hypertext Transfer Protocol                         |
| HTTPS | Hypertext Transfer Protocol Secure                  |
| IETF  | Internet Engineering Task Force                     |
| IP    | Internet Protocol                                   |
| ISO   | International Organization for Standardization      |
| IT    | Information Technology                              |
| ITSEF | Information Technology Security Evaluation Facility |
| NIAP  | National Information Assurance Partnership          |
| NIST  | National Institute of Standards and Technology      |
| OCSP  | Online Certificate Status Protocol                  |
| OE    | Operational Environment                             |
| OID   | Object Identifier                                   |
| OMB   | Office of Management and Budget                     |
| OS    | Operating System                                    |
| PII   | Personally Identifiable Information                 |
| PKI   | Public Key Infrastructure                           |
| PP    | Protection Profile                                  |

|                  |                                                       |
|------------------|-------------------------------------------------------|
| PP               | Protection Profile                                    |
| PP-Configuration | Protection Profile Configuration                      |
| PP-Module        | Protection Profile Module                             |
| RBG              | Random Bit Generator                                  |
| REC              | Request for Comment                                   |
| RNG              | Random Number Generator                               |
| RNGVS            | Random Number Generator Validation System             |
| S/MIME           | Secure/Multi-purpose Internet Mail Extensions         |
| SAN              | Subject Alternative Name                              |
| SAR              | Security Assurance Requirement                        |
| SFR              | Security Functional Requirement                       |
| SHA              | Secure Hash Algorithm                                 |
| SIP              | Session Initiation Protocol                           |
| ST               | Security Target                                       |
| SWID             | Software Identification                               |
| TLS              | Transport Layer Security                              |
| TOE              | Target of Evaluation                                  |
| TSF              | TOE Security Functionality                            |
| TSFI             | TSF Interface                                         |
| TSS              | TOE Summary Specification                             |
| URI              | Uniform Resource Identifier                           |
| URL              | Uniform Resource Locator                              |
| USB              | Universal Serial Bus                                  |
| VM               | Virtual Machine                                       |
| XCCDF            | eXtensible Configuration Checklist Description Format |
| XOR              | Exclusive Or                                          |

# Appendix F - Bibliography

Table 5: Bibliography

| Identifier | Title                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [CC]       | Common Criteria for Information Technology Security Evaluation - <ul style="list-style-type: none"><li>• <a href="#">Part 1: Introduction and General Model</a>, CCMB-2017-04-001, Version 3.1 Revision 5, April 2017.</li><li>• <a href="#">Part 2: Security Functional Components</a>, CCMB-2017-04-002, Version 3.1 Revision 5, April 2017.</li><li>• <a href="#">Part 3: Security Assurance Components</a>, CCMB-2017-04-003, Version 3.1 Revision 5, April 2017.</li></ul> |
| [GEM]      | <a href="#">Common Evaluation Methodology for Information Technology Security - Evaluation Methodology</a> , CCMB-2012-09-004, Version 3.1, Revision 4, September 2012.                                                                                                                                                                                                                                                                                                         |
| [CESG]     | <a href="#">CESG - End User Devices Security and Configuration Guidance</a>                                                                                                                                                                                                                                                                                                                                                                                                     |
| [CSA]      | <a href="#">Computer Security Act of 1987</a> , H.R. 145, June 11, 1987.                                                                                                                                                                                                                                                                                                                                                                                                        |
| [OMB]      | <a href="#">Reporting Incidents Involving Personally Identifiable Information and Incorporating the Cost for Security in Agency Information Technology Investments</a> , OMB M-06-19, July 12, 2006.                                                                                                                                                                                                                                                                            |